

# Gestão de Artefatos: Artifactory e Nexus

Otimizando o Ciclo DevOps com Repositórios de Binários e Segurança

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



# Sumário

- Pilares da Gestão de Artefatos
- Ecossistema de Pacotes Suportados
- Artifactory e Nexus: Funcionamento e Comparativo
- Segurança, Casos de Uso e Decisão Técnica
- Verificação de Conhecimento e Discussão

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



# Pilares da Gestão de Artefatos

A **gestão de artefatos** é vital no DevOps moderno, complementando o Git ao focar no armazenamento, versionamento e distribuição de binários e pacotes. Os principais objetivos incluem: **rastreabilidade** (conexão código-artefato), **velocidade de build** (através de *proxy-cache* para dependências externas), **imutabilidade** (garantindo que pacotes publicados não sejam alterados para prevenir inconsistências) e **segurança** (centralizando o controle de acesso e varreduras de vulnerabilidades antes da entrega ao cliente).



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



# Ecosistema de Pacotes Suportados

## Java e Ferramentas JVM

Gerenciadores de artefatos suportam repositórios para pacotes **Java**, como os utilizados por ferramentas de build como Maven e Gradle. Isso inclui o armazenamento e a distribuição de arquivos binários compilados, como `.jar` e .war`, essenciais para aplicações baseadas na JVM (Java Virtual Machine).`

## JavaScript e Ecosistema Web

Para o desenvolvimento web e de backend com Node.js, os gerenciadores de artefatos fornecem suporte para repositórios **JavaScript**. Isso permite a gestão eficiente de pacotes através de ferramentas como npm (Node Package Manager) e Yarn, garantindo a disponibilidade e a governança de dependências front-end e back-end.

## Python e Ciência de Dados

No ambiente Python, amplamente utilizado em ciência de dados e desenvolvimento backend, os gerenciadores de artefatos centralizam a distribuição de bibliotecas e módulos. Eles atuam como repositórios PyPI (Python Package Index) privados, facilitando a instalação de pacotes via ``pip` e garantindo a consistência das dependências em projetos Python.`



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



# Ecossistema de Pacotes Suportados

## Containerização e Orquestração

O suporte à **containerização** é crucial para arquiteturas modernas de microsserviços. Gerenciadores de artefatos funcionam como registros de imagens Docker e repositórios de gráficos Helm, permitindo armazenar, versionar e distribuir imagens de contêiner e modelos de orquestração de Kubernetes de forma segura e controlada.

## Modelos de IA/ML

Com o avanço da inteligência artificial e aprendizado de máquina, alguns gerenciadores de artefatos, como o Artifactory, têm expandido seu suporte para incluir **modelos de IA/ML**. Isso permite que as organizações versionem, armazenem e gerenciem modelos treinados, facilitando a implantação e a reprodutibilidade em pipelines de MLOps.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



# Arquitetura: Proxy, Hosted, Virtual

## Proxy: Cache Externo

Repositórios Proxy funcionam como um **cache intermediário** para *repositórios públicos* (por exemplo, Maven Central, npmjs.com ou Docker Hub). Ao requisitar um pacote que ainda não está no cache, o gerenciador faz o download uma vez, armazena-o localmente e o serve a todos os desenvolvedores subsequentes. Isso reduz a dependência de serviços externos, acelera as compilações e garante a disponibilidade dos artefatos mesmo se o repositório remoto estiver offline. A gestão do cache ajuda a controlar versões e garantir a integridade.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



# Arquitetura: Proxy, Hosted, Virtual

## Hosted: Artefatos Internos

Repositórios Hosted (Hospedados) são repositórios **privados e internos** onde as organizações publicam seus próprios artefatos proprietários. Estes incluem bibliotecas desenvolvidas internamente, módulos de microserviços, pacotes privados e imagens Docker customizadas. São essenciais para o *reuso de código* dentro da empresa, facilitando a colaboração entre equipes e a padronização de componentes, mantendo a propriedade intelectual segura e acessível apenas aos membros autorizados da equipe.

## Virtual: Abstração Unificada

Repositórios Virtuais oferecem uma **camada de abstração** que agrega um ou mais repositórios — tanto Proxy quanto Hosted — sob uma *única URL* e um único ponto de acesso. Isso simplifica drasticamente a configuração nos clientes e máquinas de desenvolvedores, pois eles interagem com uma única URL lógica em vez de configurar múltiplos repositórios. O gerenciador de repositórios decide dinamicamente qual repositório subjacente deve atender à solicitação, baseando-se em regras de roteamento predefinidas, otimizando o fluxo de trabalho.

INSTITUIÇÃO EXECUTORA



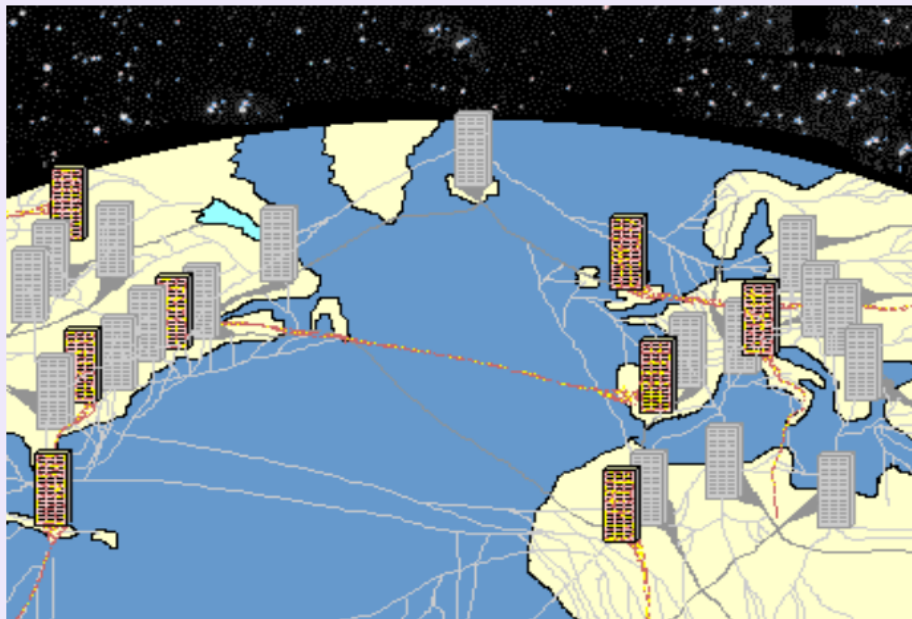
COORDENADORA



APOIO



# JFrog Artifactory: Gestão Universal



Redes globais conectam organizações centralizadas, como a gestão de artefatos.

O JFrog Artifactory é considerado o padrão ouro para grandes empresas devido à sua escalabilidade e recursos avançados. Ele se destaca pela **desduplicação de arquivos baseada em checksum**, armazenando fisicamente o arquivo apenas uma vez para múltiplos pacotes com o mesmo conteúdo e utilizando referências lógicas no banco de dados, o que resulta em economia massiva de espaço em disco, especialmente em ambientes com centenas de imagens Docker. Além disso, oferece alta disponibilidade (HA) nativa e replicação geográfica, permitindo acesso de baixa latência e consistência de dados para equipes distribuídas globalmente entre diferentes datacenters.

INSTITUIÇÃO EXECUTORA



COORDENADORA

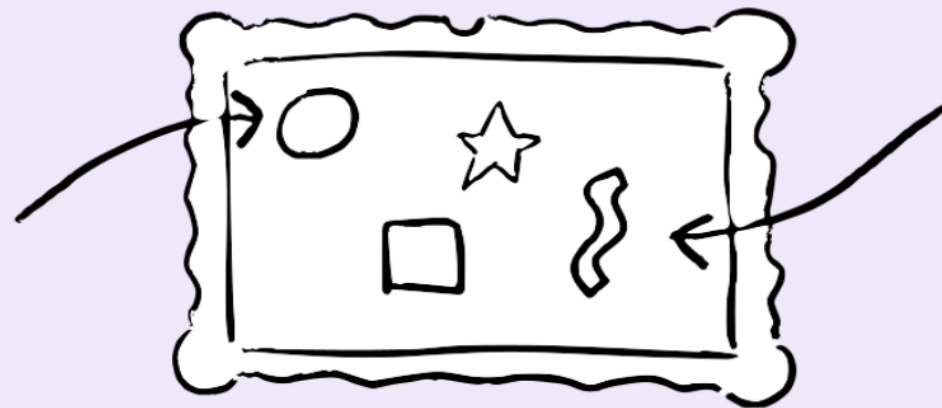


APOIO



# Sonatype Nexus: Estabilidade e OSS

O Sonatype Nexus Repository Manager destaca-se pela sua **estabilidade** e pela robustez de sua versão **OSS (Open Source Software)**, frequentemente adotada por startups e equipes de médio porte. A Sonatype foca rigorosamente na *Segurança da Cadeia de Suprimentos de Software*, mantendo o Nexus Intelligence, uma base de dados em tempo real sobre vulnerabilidades e licenças. Sua integração fluida com o ecossistema Java é notável, sendo a empresa criadora do Maven Central, o maior repositório público de bibliotecas Java do mundo.



Elementos de licenciamento aberto: combinação e remixagem livre.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



# Artifactory vs. Nexus: Comparativo

Este comparativo lado a lado destaca as principais diferenças entre JFrog Artifactory e Sonatype Nexus, abrangendo características cruciais para a gestão de artefatos em ambientes de desenvolvimento e produção.

| Característica       | JFrog Artifactory                                          | Sonatype Nexus                                           |
|----------------------|------------------------------------------------------------|----------------------------------------------------------|
| Armazenamento        | <b>**Desduplicação por Checksum**</b> (Eficiência extrema) | Baseado em arquivos/blobs                                |
| Modelos IA/ML        | Suporte avançado e nativo                                  | Focado em pacotes tradicionais                           |
| Versão Gratuita      | Artifactory OSS (Limitada a poucas tecnologias)            | <b>**Nexus OSS**</b> (Robusta e <u>multitecnologia</u> ) |
| Interface de Usuário | Moderna, focada em fluxos DevOps complexos                 | Funcional e direta, focada em estabilidade               |
| Replicação           | Multi-push e Pull (Replicação global)                      | Via licença Pro/Enterprise                               |
| Segurança            | Integrado ao JFrog Xray                                    | Integrado ao Nexus IQ Server                             |



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



# Segurança e Proxy-Cache



## Proxy de Dependências

Ao centralizar o download de pacotes externos, os gerenciadores de artefatos atuam como um **proxy de dependências**, criando um ponto único de auditoria para todos os componentes que entram no ambiente de desenvolvimento. Isso permite bloquear proativamente pacotes que contenham vulnerabilidades conhecidas (CVEs) antes que sejam utilizados, protegendo a cadeia de suprimentos de software.

## Verificação de Vulnerabilidades

Ferramentas integradas, como JFrog Xray ou Sonatype IQ Server, realizam a **verificação contínua de vulnerabilidades** em todos os artefatos armazenados. Se uma nova vulnerabilidade for descoberta em uma biblioteca já em uso, o sistema emite alertas automáticos, permitindo a remediação rápida e proativa antes que se torne um risco maior.

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO

MINISTÉRIO DA  
CIÊNCIA, TECNOLOGIA  
E INOVAÇÃO



# Segurança e Proxy-Cache

## Políticas de Governança

Os sistemas de gestão de artefatos permitem a aplicação de **políticas de governança** de forma automatizada. Isso inclui a definição de regras para impedir o uso de bibliotecas com licenças jurídicas restritivas (por exemplo, GPL em produtos proprietários) ou a garantia de conformidade com padrões de segurança internos, automatizando o controle e a conformidade.

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



MINISTÉRIO DA  
CIÊNCIA, TECNOLOGIA  
E INOVAÇÃO



# Principais Casos de Uso

## Registro Imagens Docker

Os gerenciadores de artefatos servem como o '**Single Source of Truth**' (fonte única da verdade) para imagens de contêineres prontas para produção. Eles permitem o controle de versão detalhado e o deploy consistente dessas imagens em ambientes orquestrados como o Kubernetes, garantindo que todas as equipes utilizem as versões aprovadas e seguras.

## Aceleração CI/CD

Uma das grandes vantagens é a **redução do tempo de execução** dos pipelines de Integração Contínua/Entrega Contínua (CI/CD). Em vez de baixar dependências da internet a cada novo build, o servidor de CI busca esses artefatos no gerenciador local em milissegundos, otimizando o ciclo de desenvolvimento e aumentando a eficiência operacional.

## Armazenamento Binários Internos

É possível hospedar bibliotecas Java (.jar), pacotes npm, pacotes Python ou outros binários desenvolvidos internamente. Isso facilita a colaboração entre equipes, permitindo que, por exemplo, a Equipe A utilize o código da Equipe B de forma versionada, com controle de dependências e sem a necessidade de compartilhar o código-fonte diretamente.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



# Critérios de Decisão Técnica



## Stack Tecnológica

A **stack tecnológica** utilizada pela equipe é um fator crucial. Se a organização emprega uma gama diversificada de tecnologias como C++, Go, NuGet, Maven, Python, entre outras, e necessita de suporte robusto para seus respectivos gerenciadores de pacotes (Conan, npm, pip), bem como para modelos de IA/ML, o Artifactory, com seu vasto suporte a diversos tipos de repositórios, tende a ser a solução mais completa e flexível. Em contrapartida, se o foco principal da equipe é puramente Java/npm e o orçamento para ferramentas é limitado, o Nexus OSS (Open Source Software) pode ser uma excelente e econômica alternativa, atendendo às necessidades básicas eficientemente.



## Infraestrutura de Hospedagem

A escolha da infraestrutura de hospedagem (On-Premise ou Nuvem) impacta diretamente a seleção. Um ambiente **On-Premise** (servidores locais e infraestrutura própria) requer que a equipe administre e mantenha a ferramenta e seus recursos, oferecendo maior controle. Para ambientes em **Nuvem** (AWS, GCP, Azure), ambas as ferramentas possuem versões SaaS (Software as a Service), que simplificam a gestão da infraestrutura subjacente, desonerando a equipe de operações. A decisão deve considerar a expertise da equipe em gerenciamento de infraestrutura e a estratégia de nuvem da empresa.

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



# Critérios de Decisão Técnica



## Necessidades de Armazenamento

As **necessidades de armazenamento** são um critério vital. Ambientes que enfrentam restrições de espaço em disco ou que lidam com um alto volume de imagens Docker idênticas podem se beneficiar drasticamente da funcionalidade de deduplicação de armazenamento do Artifactory. Esta característica permite armazenar uma única cópia de binários idênticos, independentemente de quantas vezes eles apareçam em diferentes pacotes ou versões, otimizando o uso do disco. O Nexus, por sua vez, armazena cada artefato individualmente, o que pode consumir mais espaço em cenários de alta redundância binária.

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



MINISTÉRIO DA  
CIÊNCIA, TECNOLOGIA  
E INOVAÇÃO



## Verdadeiro ou falso?

O Sonatype Nexus OSS é uma versão de código aberto amplamente utilizada que suporta múltiplas tecnologias além do ecossistema Java.

← Falso

Verdadeiro →

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



## ✓ Verdadeiro

*O Sonatype Nexus OSS é uma versão de código aberto amplamente utilizada que suporta múltiplas tecnologias além do ecossistema Java.*

## Explicação

O Nexus OSS é reconhecido por sua robustez e versatilidade, oferecendo suporte a uma vasta gama de formatos de pacotes e tecnologias, não se limitando apenas ao ecossistema Java, mesmo em sua versão gratuita.

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



## Verdadeiro ou falso?

O JFrog Artifactory economiza espaço em disco através da deduplicação baseada em checksum, armazenando arquivos idênticos apenas uma vez.

← Falso

Verdadeiro →

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO

MINISTÉRIO DA  
CIÊNCIA, TECNOLOGIA  
E INOVAÇÃO



## ✓ Verdadeiro

*O JFrog Artifactory economiza espaço em disco através da deduplicação baseada em checksum, armazenando arquivos idênticos apenas uma vez.*

## Explicação

Esta é uma das principais vantagens tecnológicas do JFrog Artifactory, que utiliza checksums para identificar e armazenar apenas uma cópia física de artefatos idênticos, otimizando o uso do armazenamento.

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO

MINISTÉRIO DA  
CIÊNCIA, TECNOLOGIA  
E INOVAÇÃO



## Verdadeiro ou falso?

Repositórios do tipo 'Proxy' são usados exclusivamente para hospedar o código-fonte privado da empresa, impedindo o acesso externo.

← Falso

Verdadeiro →

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO

MINISTÉRIO DA  
CIÊNCIA, TECNOLOGIA  
E INOVAÇÃO



## × Falso

*Repositórios do tipo 'Proxy' são usados exclusivamente para hospedar o código-fonte privado da empresa, impedindo o acesso externo.*

### Explicação

Repositórios 'Proxy' atuam como caches para pacotes de repositórios externos públicos, enquanto o código-fonte privado é tipicamente armazenado em repositórios do tipo 'Hosted'.

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



**Considerando os ataques à cadeia de suprimentos e a dependência de repositórios públicos, quais os riscos e impactos de não usar um gerenciador de artefatos?**

*Reflitam sobre os riscos de segurança, produtividade e continuidade de negócios.*

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



MINISTÉRIO DA  
CIÊNCIA, TECNOLOGIA  
E INOVAÇÃO



# Conclusão

- Gerenciadores de artefatos como Artifactory e Nexus são cruciais para rastreabilidade, velocidade e imutabilidade no DevOps moderno.
- Artifactory se destaca pela deduplicação por checksum e suporte avançado a modelos de IA/ML, otimizando armazenamento e performance.
- Nexus OSS oferece uma versão robusta, focando na segurança da cadeia de suprimentos e forte integração com o ecossistema Java.
- A escolha entre Artifactory e Nexus depende da stack tecnológica, necessidades de armazenamento e foco em funcionalidades de segurança.

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO

